

Authentication & Authorization Audit

Shree Shyam Dairy Farm · June 27, 2026
Next.js 16 App Router · Prisma · PostgreSQL · Custom JWT (jose)
Read-only audit — no code modified

Final score: 6.5 / 10. Production uses custom JWT (not NextAuth). Access JWT in HttpOnly cookies; refresh tokens are opaque DB tokens. RBAC is mature; email verification and Google OAuth UI are incomplete.

1. Authentication

Check	Status	Details
Auth library	Custom JWT	jose — not NextAuth/Auth.js
Session strategy	Hybrid	JWT access + DB refresh
Credentials login	Yes	POST /api/v1/auth/login
Google OAuth	Partial	Backend only, no login UI
Email verification	No flow	Schema only, not enforced
Forgot password	Yes	/forgot-password + API
Password reset	Yes	/reset-password + API
bcrypt	Yes	bcryptjs, 12 rounds
		- Key files: src/lib/auth/jwt.ts, session-manager.ts, src/app/api/v1/auth/* - NEXTAUTH_SECRET is legacy alias for JWT_ACCESS_SECRET - Phone OTP and 2FA TOTP also implemented (API level)

2. JWT

Check	Status	Details
JWT used	Yes (access)	Refresh = opaque nanoid in DB
Generated in	signAccessToken()	src/lib/auth/jwt.ts
Secret	JWT_ACCESS_SECRET	Fallback NEXTAUTH_SECRET
Cookies	HttpOnly	ssid_access, ssid_refresh
Signed/encrypted	Signed HS256	Not encrypted (JWE)

Dead code: signRefreshToken/verifyRefreshToken in jwt.ts never used.

3. Access & Refresh Tokens

Feature	Status	Notes
Access token	Yes	JWT in ssid_access cookie
Refresh token	Yes	Opaque in DB + ssid_refresh cookie
Refresh API	Yes	POST /api/v1/auth/refresh
Auto refresh client	Partial	fetchWithSession — subscriptions only
Refresh rotation	No	Same token reused
Session revoke	Yes	GET/DELETE /auth/sessions

Gap: Access cookie maxAge hardcoded 900s; JWT expiry is env-configurable.

4. Authorization

requireUser() — src/lib/auth/session.ts

- Read `ssd_access` !' verifyAccessToken (JWT) !' DB user lookup
- Returns 401 if missing, invalid, inactive, or deleted user

requirePermission() — RBAC + ABAC

- 68 permissions in `permissions.ts`
- 8 roles: CUSTOMER, ADMIN, DELIVERY, FARM_MANAGER, VETERINARIAN, ACCOUNTANT, IOT_OPERATOR, OWNER
- ADMIN/OWNER get all permissions; unknown role !' CUSTOMER
- `requireAdmin()` = `admin:farm:read` (misnamed, unused in APIs)

Protected routes

- Middleware: `/account`, `/admin`, `/m/*` — cookie presence only (no JWT verify)
- Layout guards: per-module `hasPermission` in admin layouts
- API: ~150+ routes use `requireUser/requirePermission` per handler

5. Session & Cookies

Cookie	HttpOnly	Secure	SameSite	MaxAge
<code>ssd_access</code>	true	prod	lax	15 min
<code>ssd_refresh</code>	true	prod	lax	7d / 30d remember

6. Security

Control	Status	Notes
CSRF	Partial	SameSite=lax only, no tokens
XSS/CSP	Partial	unsafe-inline/eval in CSP
Rate limiting	Partial	Auth routes only via <code>securityGate</code>
Brute-force	Yes	Login lockout
Password reset	Yes	SHA-256 hash, 15 min, revoke sessions
2FA TOTP	Yes	API + login support
Audit log	Yes	<code>audit.ts</code>

7. Multi-tenant Security

- Resolved via host subdomain !' x-tenant-slug header + ssd_tenant cookie
- assertTenantMember() on tenant admin APIs only
- withTenantScope() defined but NEVER called
- x-tenant-slug header spoofable on direct API calls
- Farm services often hardcode farmId: default

8. Razorpay

- Payment verify: HMAC SHA-256 with timingSafeEqual
- Webhook: src/app/api/payment/webhook/route.ts — signature verified
- Subscription auto-pay: partial — needs Razorpay Subscriptions on live account

9. Feature Assessment

Feature	Status	Prod Ready
Custom JWT auth	Done	Yes
Credentials login	Done	Yes
Refresh token DB	Done	Yes
Auto client refresh	Partial	No
Google OAuth	Partial	No
Email verification	Missing	No
Forgot/reset password	Done	Yes*
RBAC 8 roles	Done	Yes
CSRF	Missing	No
Multi-tenant isolation	Partial	No
Razorpay webhook HMAC	Done	Yes

*Forgot password needs RESEND_API_KEY on Vercel production.

10. Final Score: 6.5 / 10

Strengths

- JWT access + opaque DB refresh pattern
- HttpOnly cookies, bcrypt, brute-force, TOTP 2FA
- 68-permission RBAC, secure password reset
- Razorpay webhook HMAC, auth rate limiting

Missing for enterprise

- Email verification enforced on login/sensitive actions
- Google OAuth login UI + app-wide token auto-refresh
- Refresh token rotation, CSRF tokens, middleware JWT verify
- Global API rate limits, multi-tenant row isolation
- Resend on Vercel, CSP hardening (remove unsafe-inline)
- ABAC ownership on orders/subscriptions; remove dead jwt refresh code

Full markdown for ChatGPT: docs/
AUTHENTICATION_AUTHORIZATION_AUDIT.md · Generated
June 27, 2026